

IAM Permissions Explorer

Problem Statement

Cloud teams collect IAM permissions over time and rarely clean them up. Engineers grant broad access to move fast, then forget to trim it back. Over months, accounts end up full of permissions nobody uses. This is a real risk, because every unused permission is an open door for an attacker if that identity gets compromised. Security teams know this is a problem but checking it manually across accounts takes too long, so it gets skipped.

User Persona

Alex, a cloud security engineer at a mid-size company running workloads across multiple AWS accounts. He is responsible for access hygiene but is not on the platform team, so he cannot rewrite every IAM policy himself. He needs a fast way to see which roles and users have far more access than they use, understand the risk in plain terms, and either fix it directly or hand a clear, specific ask to the engineering team. He does not want to dig through CloudTrail logs by hand for every account.

Screen Annotations

Screen 1, Overview Sorted by risk so the user sees the worst problems first, not buried in a long list. Granted and used counts sit side by side so the gap is obvious without opening each role. Filters exist because a real environment has hundreds of roles, not five.

Screen 2, Detail Granted and used are split side by side so the difference is visual, not something the user has to calculate in their head. Green highlights what's actually being used, so the eye goes straight to what's safe versus what's excess.

Screen 3, Remediation Diff view instead of a plain button because the user should see exactly what changes before it happens, nobody applies a fix blind. Send to engineering exists because not every security engineer has permission to edit IAM policies directly, this gives them a real path forward instead of a dead end.

Write-Up

Features and why

The overview screen exists so Alex can triage fast. He does not need every detail up front, just enough to know where to look first. Risk badges do that job in one glance.

The detail screen answers the real question, granted versus used. This is the whole point of the tool, so it gets the most screen space and the clearest visual split.

The remediation screen turns insight into action. A security engineer finding a problem is not enough, he needs to either fix it himself or hand off something specific. The diff view shows exactly what changes, so nothing gets applied blind.

Prioritization

I built the overview first because without triage, nobody opens the tool. Detail comes second because that is where trust gets built, the user needs to see the reasoning before they act on it. Remediation comes last on purpose. If a user does not trust the data, they will not click apply, so the fix step only works once the first two are solid.

Success metrics

Time from login to identifying a high risk role. Percentage of flagged permissions actually removed within 30 days. Number of "send to engineering" actions that get resolved, since that tells you if the handoff is actually useful or just noise.

Bonus, Development Action Items

1. Pull CloudTrail events per role, filter to last 90 days, compare against the current policy.
2. Store a daily snapshot of granted vs used permissions so the dashboard loads fast.
3. Build a tool that generates the ready to apply policy JSON for the fix button.
4. Connect "Send to engineering" to a ticket system like Jira, with the diff already filled in.
5. Log every applied fix, who approved it and when, for audit purposes.